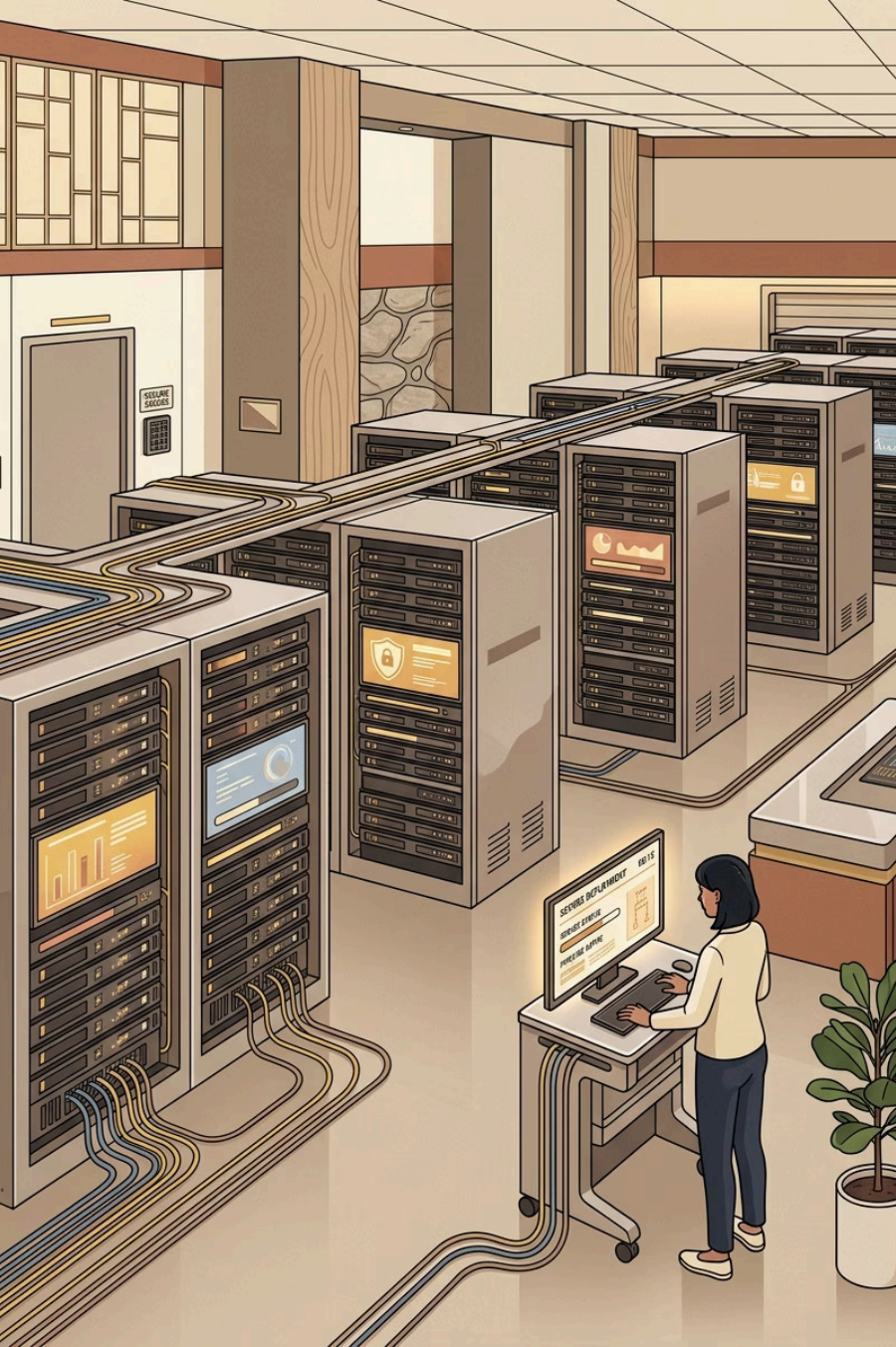




Clase 04. Controles de seguridad para la implantación

Seleccionar controles adecuados **antes, durante y después** del despliegue de software

SEGURIDAD INFORMÁTICA • ADSO SENA

DURACIÓN: 6 HORAS



Repaso corto

En clases anteriores aprendimos a **identificar y analizar riesgos** en un proyecto de software. Pero conocer el riesgo no es suficiente: el verdadero reto está en definir **qué vamos a hacer para controlarlo**.

¿Qué sabemos ya?

Identificamos amenazas y vulnerabilidades que puede tener un sistema durante su implantación, como accesos no autorizados, pérdida de datos o fallos en producción.

Ejemplo ADSO

Imagina que tu sistema de gestión de turnos tiene el riesgo de que un usuario sin permisos modifique citas. Saber que ese riesgo existe no lo elimina. Necesitas un **control concreto**: validación de roles, registro de accesos o aprobación por supervisor.

Objetivo de hoy

RESULTADO ESPERADO DE LA CLASE

Al finalizar esta sesión serás capaz de **identificar y seleccionar controles preventivos, detectivos y correctivos** aplicables al despliegue de un sistema de software real.

Identificar

Reconocer los tipos de controles existentes y cuándo aplicar cada uno.

Seleccionar

Elegir el control más adecuado para cada riesgo identificado en el sistema.

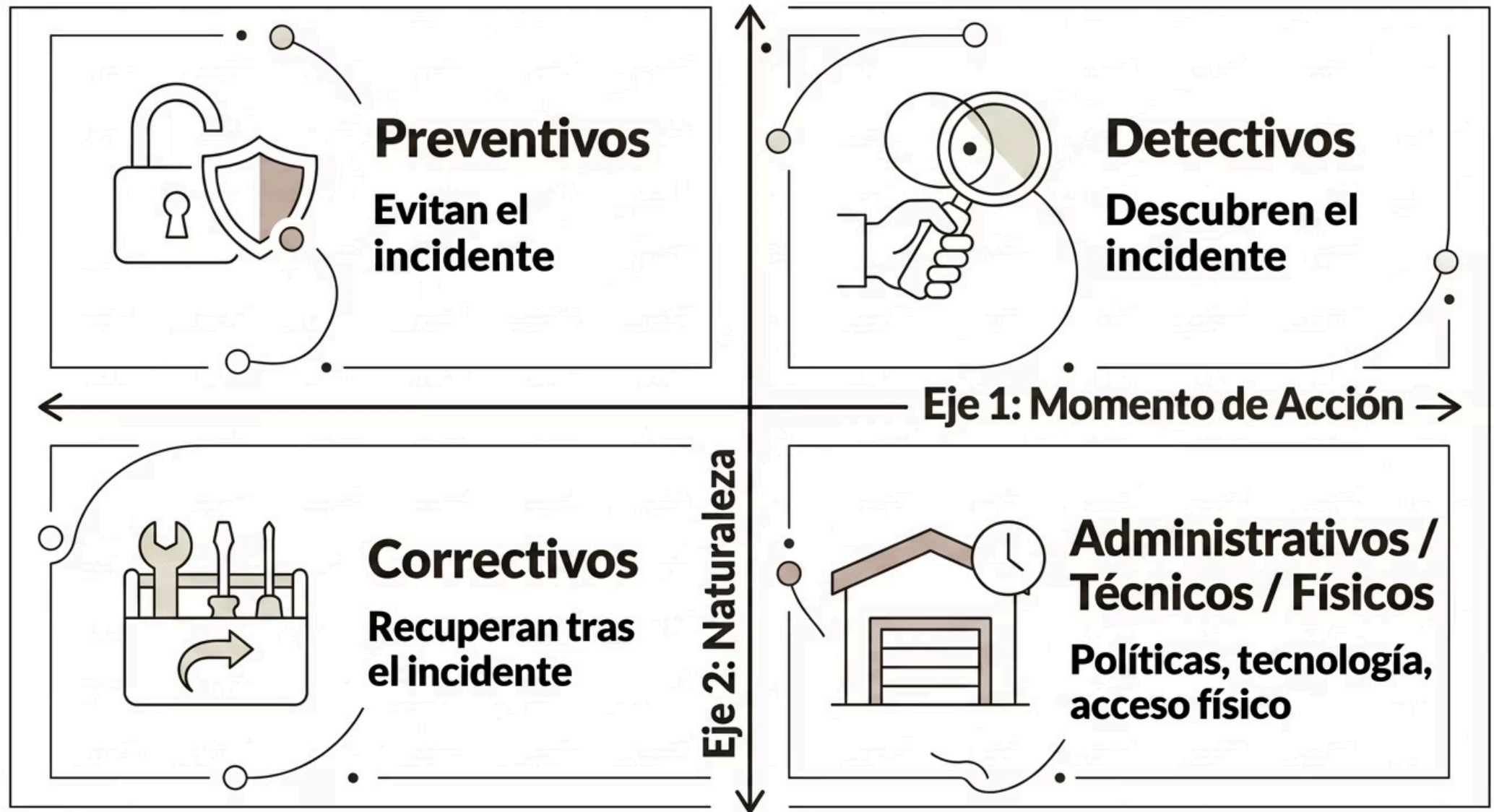
Documentar

Construir un checklist de implantación segura comentado y justificado.

 Ejemplo ADSO: En un sistema de biblioteca escolar, el objetivo es que puedas decir: "para el módulo de préstamos aplico control preventivo de autenticación, control detectivo de logs y control correctivo de backup diario."

Tipos de controles de seguridad

Los controles de seguridad se clasifican según **el momento en que actúan** (cuándo intervienen) y según **su naturaleza** (cómo están implementados). Ambas clasificaciones son complementarias y deben usarse juntas al diseñar la seguridad de una implantación.



Ningún control funciona de manera aislada. Una implantación segura combina controles de ambos ejes para cubrir todos los flancos posibles de riesgo.

Controles preventivos

Los controles preventivos tienen como misión **evitar que el incidente ocurra**. Son la primera línea de defensa y los más valorados, porque actuar antes siempre es más barato y seguro que remediar después.



Autenticación y autorización

Solo usuarios con credenciales válidas y rol asignado pueden acceder al sistema o ejecutar funciones críticas.



Revisión de código

Antes del despliegue, el código se audita para detectar vulnerabilidades como inyecciones SQL o datos sin cifrar.



Pruebas de seguridad

Se ejecutan pruebas funcionales, de regresión y de seguridad en ambientes controlados antes de pasar a producción.



Capacitación del equipo

El equipo de implantación conoce los procedimientos seguros antes de ejecutar cualquier tarea en el ambiente real.



Controles detectivos

Los controles detectivos **no impiden el incidente**, pero permiten **descubrirlo a tiempo** para limitar su impacto. Son esenciales porque ningún sistema preventivo es infalible al 100%. La detección temprana marca la diferencia entre un incidente menor y una crisis mayor.

Logs y auditoría

Registros automáticos de todas las acciones del sistema: quién accedió, cuándo y qué hizo.

Alertas automáticas

El sistema notifica al administrador cuando detecta comportamientos anómalos, como múltiples intentos de login fallidos.

Monitoreo de red

Herramientas que analizan el tráfico de red y detectan patrones sospechosos o accesos desde IPs no autorizadas.

Revisiones periódicas

Auditorías programadas del sistema en producción para verificar que los controles siguen activos y correctos.

¿Por qué son tan importantes?

En una implantación real, los primeros días en producción son los más críticos. Un control detectivo activo puede alertar sobre un error de configuración o un acceso indebido en minutos, antes de que cause daño irreversible.



Sin controles detectivos, un incidente puede pasar semanas sin ser descubierto, multiplicando el daño causado.

Controles correctivos

Los controles correctivos entran en acción **cuando el incidente ya ocurrió**. Su objetivo es **recuperar la operación normal** en el menor tiempo posible y con el menor daño posible. No son sinónimo de fracaso: son parte fundamental de una estrategia de seguridad madura.

1

Detección

El incidente es identificado por alertas, usuarios o auditoría.

2

Contención

Se aísla el componente afectado para evitar que el problema se propague al resto del sistema.

3

Restauración

Se activa el backup, se revierte el cambio o se aplica el parche correctivo probado.

4

Verificación

Se confirma que el sistema volvió a operar correctamente y se documenta el incidente.

Ejemplos: restauración desde backup, rollback de versión, parches de emergencia, activación de plan de continuidad del negocio.

Controles administrativos

Los controles administrativos son los **acuerdos, políticas y procedimientos formales** que definen cómo debe comportarse el equipo humano ante la seguridad. Son la base sobre la que se apoyan los controles técnicos y físicos.



Políticas de seguridad

Documento formal que establece qué está permitido y qué no durante la implantación.



Definición de roles

Quién puede desplegar, quién aprueba, quién valida y quién responde ante un incidente.



Procedimientos de aprobación

Ningún cambio en producción se ejecuta sin la firma del responsable técnico y del líder del proyecto.



Capacitación obligatoria

Todo miembro del equipo debe conocer y firmar las políticas antes de participar en la implantación.

 Ejemplo ADSO: En el sistema de matrícula escolar, el control administrativo establece que solo el coordinador TI puede autorizar el acceso a la base de datos de producción, y toda aprobación queda registrada por escrito antes de ejecutarse.

Controles técnicos

Los controles técnicos son las **herramientas y mecanismos tecnológicos** implementados directamente en el sistema o la infraestructura. Son los más visibles en el trabajo diario del técnico ADSO y los más directamente ligados al código y la configuración del sistema.



Firewall y segmentación de red

Bloquea tráfico no autorizado entre el servidor de aplicaciones y el exterior, o entre ambientes de desarrollo y producción.



Cifrado de datos

Los datos sensibles se almacenan y transmiten cifrados (HTTPS, cifrado de base de datos) para que sean inútiles en caso de interceptación.



MFA y gestión de accesos

La autenticación multifactor agrega una capa extra de verificación más allá de la contraseña para acceder a entornos críticos.



Logs, Backup y Hardening

Registro de eventos del sistema, copias de seguridad automáticas y configuración reforzada del servidor (hardening) reducen la superficie de ataque.

Controles físicos y operativos

Los controles físicos y operativos protegen el **entorno donde reside el sistema**: los equipos, los servidores, las instalaciones y los procedimientos de manipulación. Con frecuencia son subestimados, pero una brecha física puede anular todos los controles técnicos.

Controles físicos

- **Control de acceso al servidor:** solo personal autorizado entra a la sala de servidores (llave, tarjeta, biometría).
- **Cámaras y vigilancia:** registro visual de quién accede y cuándo a las instalaciones.
- **Protección de equipos:** los equipos de desarrollo y producción no se mezclan ni se usan para actividades personales.

Controles operativos

- **Custodia de respaldos:** las copias de seguridad se almacenan en un lugar físico separado del servidor principal.
- **Manejo de medios:** los USB y discos externos usados en producción se registran, cifran y se destruyen cuando ya no sirven.
- **Procedimientos de mantenimiento:** cualquier intervención física al servidor queda documentada en una bitácora operativa.

❏ Un técnico ADSO que trabaja en una empresa con datacenter propio debe conocer estos controles aunque no sea el responsable directo de aplicarlos.

Checklist previo al despliegue

Antes de publicar o activar cualquier sistema en producción, el equipo debe verificar que **todos los controles mínimos están en su lugar**. Esta lista de verificación es el primer insumo para la evidencia escrita de esta clase.

Código y ambiente

- ✓ Revisión de código completada y aprobada
- ✓ Pruebas funcionales y de seguridad ejecutadas
- ✓ Ambiente de producción separado y limpio
- ✓ Variables de entorno configuradas correctamente

Accesos y permisos

- ✓ Roles y permisos de usuario definidos y probados
- ✓ Credenciales de producción distintas a las de desarrollo
- ✓ MFA activado en cuentas administrativas

Datos y respaldos

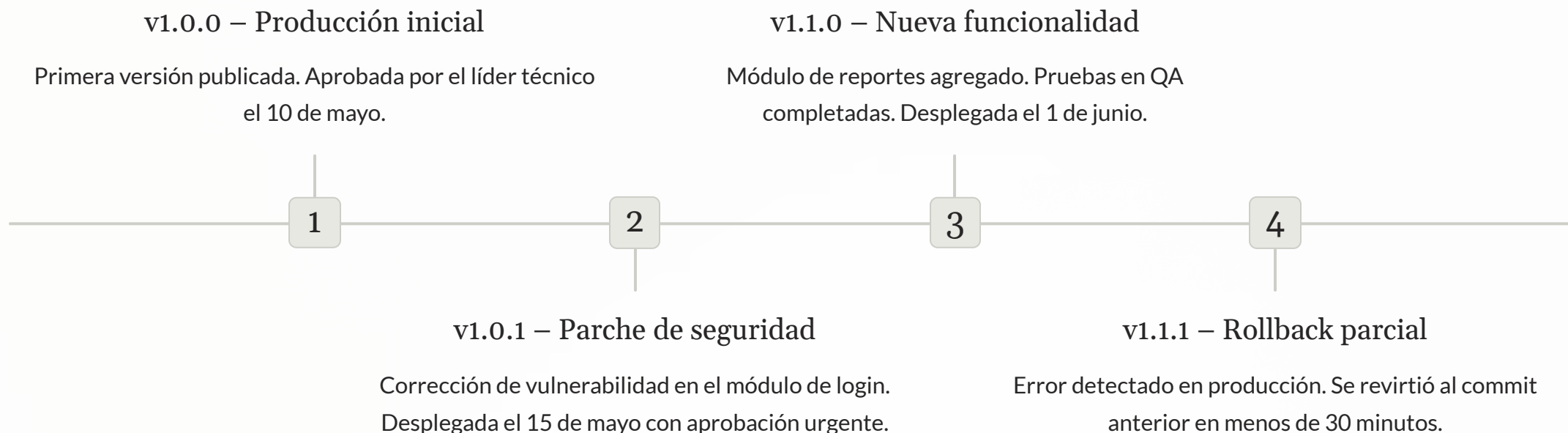
- ✓ Backup previo al despliegue realizado y verificado
- ✓ Datos sensibles cifrados en tránsito y en reposo
- ✓ Plan de rollback documentado y probado

Aprobaciones y comunicación

- ✓ Aprobación escrita del responsable técnico
- ✓ Notificación a usuarios o clientes del despliegue
- ✓ Ventana de mantenimiento programada y comunicada

Versionado y control de cambios

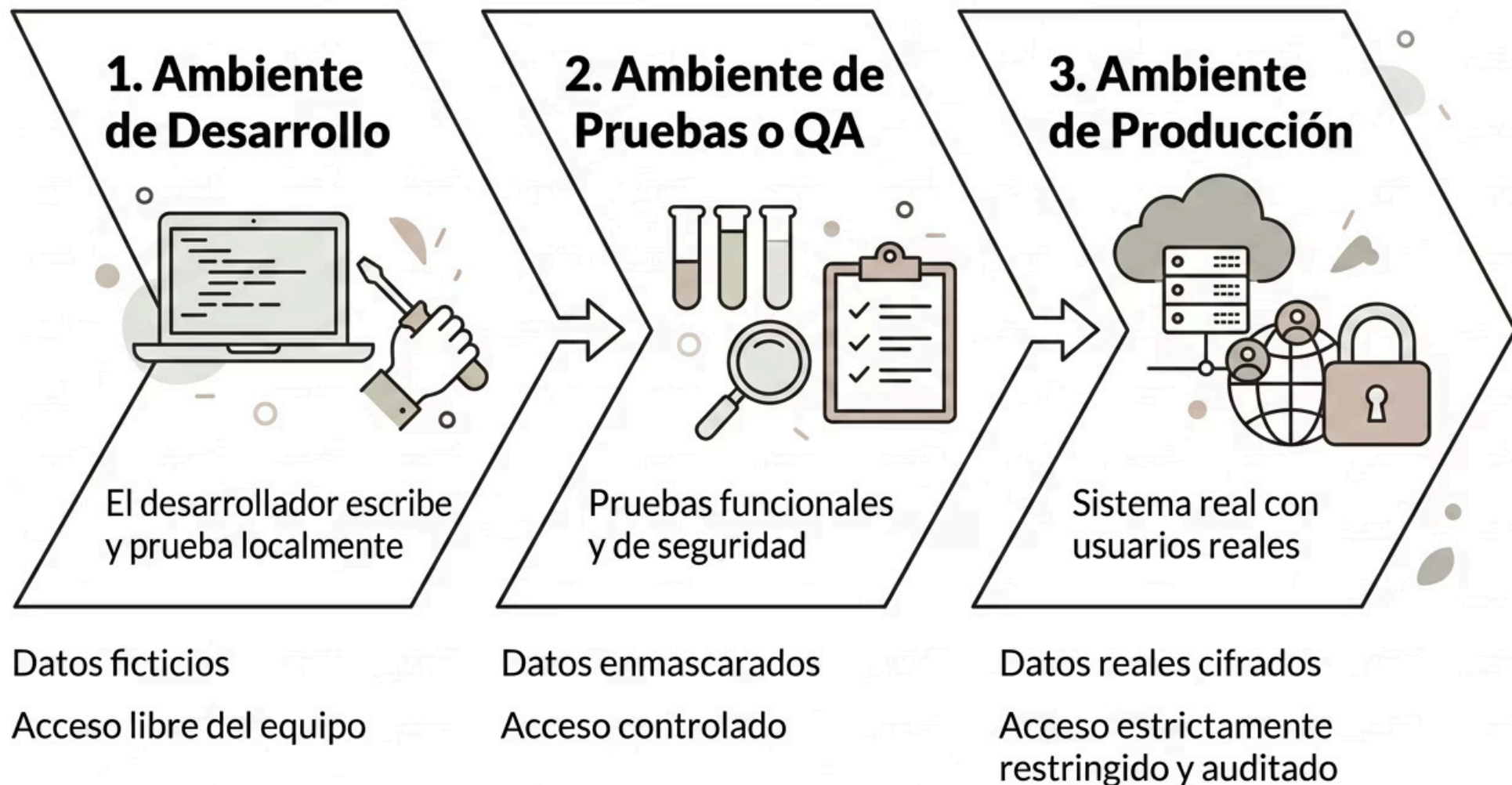
Todo cambio en el sistema debe ser **trazable**: debe quedar claro qué cambió, quién lo cambió, cuándo y por qué. El versionado no es solo una buena práctica de desarrollo; es un control de seguridad que permite auditar, revertir y justificar cada modificación.



i Ejemplo ADSO: El sistema de control de inventario de una ferretería usa Git con ramas separadas por ambiente (dev, staging, main). Cada merge a main requiere revisión de un compañero y genera automáticamente un tag de versión con fecha y autor registrados.

Ambientes separados: Desarrollo, Pruebas y Producción

Uno de los errores más frecuentes y peligrosos en implantaciones es **mezclar ambientes**. Cada ambiente tiene un propósito distinto y debe estar aislado de los demás para garantizar la integridad del sistema y la protección de los datos reales.



⊗ Nunca se deben usar datos reales de clientes en el ambiente de desarrollo ni de pruebas. Esto es un requisito de seguridad y, en muchos casos, también legal (Ley de Protección de Datos).

Aprobaciones: quién autoriza, quién ejecuta y quién valida

Un control fundamental de seguridad en cualquier implantación es la **separación de funciones**: la misma persona no puede autorizar, ejecutar y validar un cambio al mismo tiempo. Esta separación previene errores, fraudes y cambios no autorizados.

Quien autoriza

Líder del proyecto o coordinador TI. Revisa la solicitud de cambio, verifica que las pruebas están completas y firma la aprobación formal antes de cualquier acción en producción.

Quien ejecuta

Desarrollador o técnico de despliegue. Aplica el cambio en producción siguiendo exactamente el procedimiento aprobado. No puede alterar el alcance sin una nueva autorización.

Quien valida

Tester o analista de calidad. Verifica que el sistema funciona correctamente después del despliegue y que no se introdujeron nuevos errores o brechas.

Esta separación queda registrada en el **acta de despliegue**, documento obligatorio que soporta la trazabilidad del proceso.

Monitoreo inicial tras el despliegue

Las primeras horas después de poner un sistema en producción son las más críticas. El **monitoreo activo inicial** permite detectar problemas antes de que afecten a los usuarios o comprometan la seguridad del sistema.

¿Qué se debe revisar?

- **Estado del servicio:** ¿el sistema responde correctamente a las solicitudes?
- **Logs de errores:** ¿hay excepciones, errores 500 o mensajes inesperados?
- **Consumo de recursos:** ¿CPU, RAM o disco están en rangos normales?
- **Accesos y autenticaciones:** ¿se están registrando intentos de acceso anómalos?

Situación real de despliegue

Un equipo ADSO despliega el módulo de facturación de una empresa a las 6:00 p.m. del viernes. A las 6:45 p.m., el monitoreo detecta que el 30% de las facturas generadas no tienen número consecutivo correcto. Gracias al monitoreo activo, se identifica el error de configuración en menos de una hora y se aplica el correctivo antes de que los clientes reporten el problema el lunes. Sin monitoreo, el error habría afectado cientos de registros.

Registro de incidentes

Todo incidente que ocurra durante o después del despliegue **debe quedar documentado**. El registro no es burocracia: es la evidencia que permite aprender, mejorar controles, cumplir auditorías y demostrar que el equipo actuó con responsabilidad.

1

Descripción del incidente

¿Qué ocurrió exactamente? Fecha, hora, componente afectado y síntoma observado.

2

Impacto y alcance

¿Cuántos usuarios o datos fueron afectados? ¿Cuánto tiempo duró la afectación?

3

Causa raíz identificada

¿Por qué ocurrió? ¿Fue un error de código, de configuración, de procedimiento o de control insuficiente?

4

Acciones tomadas

¿Qué se hizo para contener el incidente y restaurar el servicio? ¿Quién actuó y en qué tiempo?

5

Lecciones aprendidas y mejoras

¿Qué control se debe agregar o mejorar para que este incidente no vuelva a ocurrir?



Situación real: En un sistema de reservas de hotel, tras el despliegue se detectó que las reservas de dos clientes quedaban asignadas al mismo cuarto. El registro del incidente permitió identificar que faltaba validación de unicidad en la base de datos, y ese control fue agregado en la versión siguiente.

Caso: Despliegue exitoso sin monitoreo ni validación posterior



El contexto

Un equipo de desarrollo ADSO termina el despliegue de un sistema de nómina para una empresa mediana. El despliegue técnico fue exitoso: el sistema quedó en línea, sin errores aparentes. El equipo se retiró satisfecho a las 5:00 p.m.

Lo que ocurrió después

Durante los siguientes tres días, el sistema calculaba incorrectamente las horas extras de los empleados debido a un error en una fórmula de redondeo que no fue detectado en las pruebas.

Al no existir monitoreo activo ni revisión de logs post-despliegue, nadie del equipo técnico detectó el problema. Fueron los empleados quienes lo reportaron al recibir sus pagos incorrectos el viernes siguiente.

- ❌ El daño: 87 empleados con liquidación incorrecta, reproceso manual de nómina, pérdida de confianza del cliente y una reclamación formal ante el área de TI.

Análisis del caso: ¿qué controles faltaron?

El caso anterior es un ejemplo clásico de **implantación técnicamente exitosa pero operativamente fallida** por ausencia de controles detectivos y correctivos. Analicemos qué debió existir.

Control faltante 1	Control faltante 2	Control faltante 3
Pruebas con datos representativos: las pruebas no incluyeron casos de horas extras. Un conjunto de datos de prueba completo habría detectado el error antes del despliegue.	Monitoreo post-despliegue: no hubo revisión de logs ni de resultados del sistema en las primeras 24–48 horas. Un panel de monitoreo con alertas habría detectado cálculos anómalos.	Validación por parte del cliente: no hubo un período de aceptación formal donde el cliente verificara resultados reales antes de liberar el sistema a todos los usuarios.

¿Qué evidencia debió existir?

- Acta de pruebas firmada con los casos de prueba ejecutados y sus resultados esperados vs. obtenidos.
- Registro de monitoreo de las primeras 48 horas: logs revisados, sin anomalías reportadas.
- Acta de aceptación del cliente firmada antes de liberar el sistema a producción total.
- Plan de rollback documentado para actuar en menos de 2 horas ante cualquier fallo crítico.

Evidencia escrita solicitada

ENTREGA OBLIGATORIA

FORMATO: WORD

Debes subir un **Documento Word** con el **Checklist de Implantación Segura**, comentado y justificado punto por punto. No basta listar los ítems: cada punto debe explicar para qué sirve y qué problema previene.

¿Cómo debe verse la evidencia?

Cada ítem del checklist debe tener tres elementos:

1. **El control:** nombre claro del control (ej: "Backup previo al despliegue").
2. **Para qué sirve:** qué protege o garantiza este control.
3. **Qué problema previene:** qué incidente o riesgo concreto evita o mitiga.

Ejemplo ADSO aplicado

Control: Separación de ambientes

Para qué sirve: garantizar que las pruebas no afecten datos reales.

Problema que previene: evita que un error de prueba borre o corrompa la base de datos de producción del sistema de inventario.

Control: MFA en cuentas de administrador

Para qué sirve: agregar una segunda capa de verificación al acceso.

Problema que previene: impide que un atacante acceda al panel de administración con solo robar una contraseña.

Cierre y preguntas

Control sin evidencia no sostiene la implantación

Un control que se aplicó pero no se documentó, es un control que no existe ante una auditoría, un incidente o una reclamación del cliente. La seguridad en la implantación no termina con el despliegue técnico: termina cuando el proceso está documentado, auditado y verificado.

Recuerda siempre

Preventivo + Detectivo + Correctivo =
Estrategia completa. Ninguno funciona solo.

Tu evidencia demuestra

Que piensas como técnico responsable: no solo que el sistema funciona, sino que funciona de forma segura y trazable.

Próxima clase

Gestión de vulnerabilidades y pruebas de penetración básicas aplicadas al sistema en producción.

✅ ¡Excelente trabajo hoy! Recuerda subir tu checklist comentado en Word antes de la próxima sesión. ¿Preguntas antes de cerrar?